

RED TEAM ENGAGEMENT REPORT

OPERACIÓN SILENT BRIDGE — Lab-02

CAMPO	DETALLE
Nombre de operación	SILENT BRIDGE
Clasificación	CONFIDENCIAL — Solo uso educativo
Adversario emulado	APT41 (Double Dragon) — MSS China
Objetivo primario	Compromiso de PC-01 (10.0.3.7) en red interna segmentada
Objetivo secundario	SAM dump + persistencia en PC-01
Entorno	Red segmentada: PROD (10.0.2.200/10.0.3.200), GIT (10.0.3.150), PC-01 (10.0.3.7)
Período	13/05/2026 — 15/05/2026
Operador	Adrián Camacho

1. RESUMEN EJECUTIVO

La operación SILENT BRIDGE emula las TTPs de APT41 (Double Dragon) en un entorno de red segmentada de tres nodos. Se explotó una vulnerabilidad de ejecución remota de código en Webmin 1.890 (CVE-2019-12840) para comprometer el servidor PROD expuesto en Internet. Desde PROD se estableció un túnel TLS con Ligolo-ng hacia la red interna, se encontraron credenciales en el historial de Git del servidor GIT, y se comprometió PC-01 via WinRM usando reutilización de credenciales.

2. ALCANCE Y TOPOLOGÍA

HOST	IP	SO	ROL
PROD	10.0.2.200 / 10.0.3.200	Ubuntu 22.04	Servidor web expuesto — Pivote
GIT	10.0.3.150	Ubuntu 22.04	Git server — Red interna
PC-01	10.0.3.7	Windows 11	Workstation — Objetivo final
Kali	10.0.2.9	Kali Linux 2026.1	Máquina operadora

3. KILL CHAIN

FASE	TÉCNICA	RESULTADO	MITRE
1 — Recon	Nmap + web fingerprint	Webmin 1.890 en PROD:10000	T1046
2 — Initial Access	CVE-2019-12840 RCE	Shell root en PROD	T1190
3 — Pivoting	Ligolo-ng TLS tunnel	Red 10.0.3.0/24 accesible desde Kali	T1572
4 — Recon Interna	Nmap via túnel	GIT (10.0.3.150) + PC-01 (10.0.3.7) descubiertos	T1046
4 — Cred. Discovery	Git history	thomas:iamthegreatest en commit antiguo	T1552.001

5 — Lateral Mov.	Evil-WinRM	Shell thomas (Admin local) en PC-01	T1021.006
6 — C2	Sliver beacon relay	Beacon SUDDEN_COMMUNICATION via PROD-013	T1021.006
7 — Persistence	schtasks + reg save SAM	Persistencia + SAM dump obtenido	T1053.005

4. VULNERABILIDADES IDENTIFICADAS

ID	DESCRIPCIÓN	CVSS	MITRE
V-01	CVE-2019-12840 — Webmin 1.890 RCE autenticado via correo electrónico	8.8 Alta	T1190
V-02	Credenciales hardcodeadas en historial Git — thomas:iamthebest	7.5 Alta	T1552.001
V-03	Reutilización de contraseñas — misma cred en Git y WinRM de PC-01	6.0 Alta	T1078
V-04	Webmin desactualizado — versión 1.890 (2019) sin parches de seguridad	7.0 Alta	T1190
V-05	Red interna no accesible desde DMZ pero sin segmentación adicional post-PROD	6.0 Media	T1502

5. RECOMENDACIONES

PRIORIDAD	RECOMENDACIÓN
CRÍTICA	Actualizar Webmin a versión actual — EOL en 1.890
CRÍTICA	Implementar git-secrets o gitleaks en todos los repos para prevenir commits con credenciales
ALTA	Política de contraseñas únicas por sistema — no reutilizar entre servicios
ALTA	Implementar rotación automática de credenciales (Vault, CyberArk)
MEDIA	Añadir segmentación adicional entre PROD y red interna — PROD no debe ver directamente PC-01
MEDIA	Monitorizar conexiones WinRM desde IPs no corporativas